

Cool × Contrast

Where confidential execution and verifiable AI-change evidence meet — and why the combination is worth more to each side than either is alone.

DOCUMENT	Joint-value analysis and partnership case
PREPARED BY	Northwind Cipher Pvt. Ltd.
FOR DISCUSSION WITH	Edgeless Systems GmbH
COMPANION DOCUMENT	Cool × Contrast — Technical Documentation
WORKING INTEGRATION	Built, tested, reproducible (npm run demo:contrast)
DATE	6 October 2026

STATUS OF THESE CLAIMS

This document makes a commercial and architectural case; it does not overstate the engineering. The integration described is implemented and tested — 152 automated tests, 33 specific to it, against certificates produced by Contrast's own code — but it has not run on confidential hardware, and Cool does not yet independently verify the hardware quote. Section 8 lists every boundary. Nothing here implies that Edgeless Systems has reviewed, endorsed or agreed to anything.

1 • The one-paragraph version

Contrast proves a workload ran confidentially. Cool proves what changed inside it. Each is a complete answer to a question the other cannot answer, and enterprises buying confidential AI are being asked both questions at once — usually by the same auditor, in the same room.

The integration described here binds a Cool evidence record to a specific Contrast workload cryptographically, so that one artefact answers both. It took no new dependency on either side, no change to Contrast, and no new trusted third party. It is built and tested today.

THE JOINT CLAIM, IN THE FORM AN AUDITOR WOULD ACCEPT

This AI change record was produced by a specific confidential workload whose execution environment can be independently attested — and you can check both halves yourself, offline, years later, without trusting Northwind Cipher, Edgeless Systems, or the operator who ran it.

2 • The gap neither closes alone

This is not a case of two products that overlap and could be rationalised. They are adjacent, and the seam between them is exactly where enterprise AI governance questions land.

	Contrast alone	Cool alone	Together
Was the workload protected while it ran?	Yes — attested against a signed manifest	Cannot say	Yes
Which prompt, model and permissions was it running?	Cannot say	Yes — committed and signed	Yes
Who changed it, and when?	Cannot say	Yes — actor, time, ordered log	Yes
Was the record altered afterwards?	Not applicable	No — hybrid signature over a canonical commitment	No
Can a third party check it in two years, offline?	The pod is gone; attestation is live-only	Yes, but says nothing about where it ran	Yes, including where it ran
Could the evidence have come from somewhere else?	Not applicable	Yes — nothing ties a receipt to an attested workload	No — that is the binding

2.1 Why the last row is the whole point

Running Cool inside a Contrast pod without an integration produces receipts that are cryptographically sound and say nothing about Contrast. The measurement is absent from the signed record; nothing stops a receipt produced on a developer's laptop from being presented as the output of the confidential workload.

Closing that required finding the right seam rather than bolting metadata together. **Contrast's attestation is a**

credential, not a quote: the Coordinator verifies each pod's hardware report and then issues the pod a mesh certificate *carrying the measurements it verified*, bound to a key only that pod holds. That makes it something Cool can bind to cryptographically, offline, with no Coordinator contact at verification time. The technical document develops this; the commercial point is that the seam exists and is clean.

3 • The intersection map

Seven places where the two systems actually touch. Every row is implemented, not proposed.

Contrast provides	Cool uses it to	Joint outcome
A workload secret released only to a pod that passed attestation	Derive its signing key (HKDF-SHA256)	No key to steal. Outside the attested workload the signing key is not derivable at all — no key in the image, in a vault, or in CI
A mesh certificate carrying MRTD, RTMRs and the policy hash	Seal that identity inside the signed record and bind its own key to the certificate	A receipt that names the workload that produced it, in the Coordinator's hand
A pod-held P-256 key certified by the Coordinator	Sign a commitment to the Cool public key	Receipt A cannot be presented as workload B's
<code>manifest.json</code> with <code>Policies</code> and <code>ReferenceValues</code>	Pin by digest, and check the policy hash against it	"This ran under the manifest I reviewed" becomes a checkable statement
A Coordinator root CA obtained via <code>contrast verify</code>	Require it as the trust anchor for the workload domain	The reader's own attestation of the Coordinator is what makes every receipt meaningful
Workload-secret stability across restarts and manifest updates	Keep one signing identity across pod churn	A continuous audit trail in a cluster that reschedules
Encrypted volumes (<code>secure-pv</code>)	Persist the transparency log across restarts	Ordering and completeness provable over time, not one tree per pod lifetime

NOTE WHAT IS NOT ON THIS LIST
No change to Contrast. No fork, no patch, no vendored code, no feature request. Cool reads five files Contrast already writes into every pod and parses a certificate Contrast already issues. That is the entire integration surface, which is why it was possible to build it in one pass and why it will not break on Contrast's next release.

4 • What Contrast gains

Stated as specifically as possible, and only where the integration actually delivers it.

4.1 An answer to the question confidential computing cannot answer

The hardest objection to confidential AI in a regulated buyer's procurement process is not “is the memory encrypted”. It is some version of: *you have told me the workload was protected; now tell me what it was doing, prove it has not been edited since, and let my auditor check that without calling you.*

Attestation is live-only by nature: it establishes a property of a running machine. Once the pod is gone, the attestation is a memory. Cool converts a moment of attestation into a **durable artefact** that still carries the measurement, the policy hash and the manifest digest years later. That extends the value of every attestation Contrast performs beyond the lifetime of the pod that performed it.

4.2 A reason the Coordinator's work matters downstream

Today the Coordinator's verdict is consumed by the service mesh and by whoever runs `contrast verify`. Under this integration, that verdict is also what makes an auditor's verification succeed or fail — the `workload` domain cannot reach `pass` without a Coordinator root the reader pinned themselves.

That puts the Coordinator at the centre of an audit workflow rather than only a deployment workflow, and it does so without expanding what Contrast has to trust or maintain.

4.3 Differentiation against plain Confidential Containers

Contrast's architectural advantage over a bare CoCo deployment is the Coordinator: a manifest, reference values, admission control, an attested PKI. That advantage is real and somewhat hard to demonstrate in a short meeting, because its output is a certificate rather than something a buyer can hold.

This integration gives it a demonstrable output. The seven-act demo ends with four forgery attempts that **must** fail — a stolen credential, a full double swap, a Coordinator nobody attested, a rebuilt image — and each failure is attributable to a specific Contrast guarantee. It is a concrete way to show why the Coordinator exists.

4.4 Reach into AI governance budgets

Confidential computing is typically sold to a platform or security team against an infrastructure budget. AI governance, model risk management and audit readiness are usually a different buyer with a different budget, and often a more urgent one.

Driver	What the buyer has to evidence	Where this integration lands
EU AI Act, high-risk systems	Record-keeping and traceability over the system's lifecycle; post-market monitoring	Change records with actor, time and ordering, bound to the attested workload

Model risk management (e.g. SR 11-7 lineage practice)	Model and configuration change control, with independent review	An auditor verifies offline, without operator cooperation
ISO/IEC 42001 AI management systems	Documented control over changes to the AI system	The same artefact serves the control and its evidence
Internal audit of agentic systems	What permissions did the agent have, and when did they widen?	agent-permission change records in the same signed log

AN EXPLICIT NON-CLAIM

Nothing here makes anyone compliant with anything. Regulations require processes, judgement and documentation; this produces evidence that a process was followed. That is a necessary input to an audit, not a substitute for one — and it is worth saying plainly, because the opposite claim is common in this market and does not survive contact with an auditor.

4.5 A reference architecture, not a one-off

The integration binds to [WorkloadIdentityV1](#), a platform-neutral shape in Cool's receipt format, with [platform: "contrast"](#) as its first implementation. The surface Contrast exposes — measurement-released secret, plus a credential naming the workload — is the general pattern. Any orchestrator that provides those two things can be bound the same way, which means Contrast is the reference implementation of a pattern rather than a special case in someone's SDK.

5 • What Cool gains

5.1 A hardware root it does not have to build

Cool's existing confidential-compute path is Phala dstack on Intel TDX. Contrast adds **AMD SEV-SNP**, bare-metal and AKS deployment models, and Kubernetes-native operation — through one integration, with no second attestation stack to maintain. The evidence plane, capture queue, transparency log and verifier are entirely unchanged; only the attestation source differs.

5.2 Manifest-based policy it can pin

On its own, Cool can pin a measurement an operator gave it, which is only as trustworthy as the process that produced it. Contrast supplies something better: a signed manifest listing every pod allowed to run and the reference values their hardware must satisfy. Cool pins that manifest by digest and checks the credential's policy hash against it, so a receipt states which reviewed manifest governed it.

5.3 The key-management problem removed

The single most common objection to signed-evidence systems is the signing key: who holds it, where it lives,

what happens when it leaks, who could have forged the log. Deriving the key from the Contrast workload secret removes the question rather than answering it. There is no key to provision, rotate, or subpoena — and Northwind Cipher cannot forge a customer's records even if it wanted to.

5.4 Credibility by construction

Cool's conformance tests run against certificates produced by **Contrast's own Go packages**, so they assert agreement between two independent implementations rather than self-consistency. That is a materially stronger claim than a test suite can usually make, and it is only available because Contrast's relevant code is readable.

6 • What the customer gains

Three things, in the order they tend to be asked for.

1. **One artefact, both answers.** The platform team's attestation story and the audit team's change-control story become the same signed record, rather than two systems to reconcile when someone asks how they relate.
2. **Verification without cooperation.** An auditor, regulator or counterparty verifies with the receipts plus two files — the Coordinator root and the manifest — and no network, no account, no access to the cluster, and no trust in either vendor. Verification is fully offline and tested to make no network call.
3. **No new trusted party.** The integration introduces no service, no registry, no hosted verifier and no escrow. The trust set is the silicon vendor, the Coordinator the reader attested themselves, and standard cryptography.

6.1 The operational cost of adopting it

Honestly small, which matters more than it sounds.

```
runtimeClassName: contrast-cc                # already there
contrast.edgeless.systems/workload-secret-id: default/ai-service # one annotation
COOL_CONTRAST_ROOT=/contrast                 # one env var
```

Plus two lines in the application: construct `ContrastWorkload`, hand it to `Cool`. No call sites change. One extra deployment step publishes the manifest to the pod so each receipt can seal its digest.

7 • Commercial shape

7.1 Why the licensing is uncomplicated

	Contrast	Cool
Licence	BUSL-1.1 (Edgeless Systems)	BUSL-1.1 (Northwind Cipher)
Code redistributed by the other	None	None
Build-time dependency on the other	None	None at runtime; the fixture generator imports Contrast only inside a Contrast checkout
Coupling	Five files Contrast already writes; one certificate it already issues	A reader of those files

Each side keeps its own licensor, terms and commercial thresholds. There is no joint IP to negotiate before the integration is useful, which means a technical collaboration can start well ahead of any commercial agreement.

7.2 Who sells what

- **Edgeless sells confidential execution.** Unchanged. Cool becomes an additional reason the Coordinator is worth having, and an additional answer for the governance questions that arrive late in a confidential-AI sale.
- **Northwind Cipher sells verifiable evidence.** Contrast becomes the recommended Kubernetes deployment model for it, and the path to SEV-SNP.
- **Neither resells the other.** The integration is a documented reference architecture, not a bundled product — which keeps both pipelines independent.

7.3 What a joint reference architecture would contain

Most of it exists; the gaps are listed honestly in section 8.

Component	Status today
Architecture and trust-model document	Done — the companion technical document
Working integration in a published SDK	Done — cool-nwc/contrast , no new dependency
Conformance tests against Contrast's own code	Done — 33 tests
Kubernetes manifest, Dockerfile, deploy script	Written , not yet applied to a live cluster
End-to-end demonstration	Done — runs in ~90 seconds with no cluster
Independent verifier an auditor can run	Done — CLI and a 70-line script

Validation on real TDX / SEV-SNP hardware	Not done — needs a cluster
Independent quote verification against DCAP	Not done — the highest-value next step
Confidential-GPU attestation joined to the evidence	Not done — both sides have the pieces

8 • Honest boundaries

Every claim in this document is bounded by the following. They are stated here rather than in a footnote because a partnership conversation that starts with an overstatement is worse than one that starts slowly.

1. **No hardware run.** Nothing described has executed on Intel TDX or AMD SEV-SNP. The conformance fixtures carry a TDX quote constructed in software. What is proven is that Cool binds to, parses and enforces Contrast's credential format correctly — not that any hardware was involved.
2. **The Kubernetes manifests are unvalidated.** They are written against Contrast's current generator and have not been applied to a cluster. The Dockerfile has a placeholder base-image digest.
3. **Cool does not verify the hardware quote.** It verifies that the credential chains to a Coordinator root the reader pinned. A compromised Coordinator could certify an arbitrary workload. This is Contrast's own trust assumption, which Cool inherits and narrows by requiring the reader to attest the Coordinator independently — and the verdict says `workload: pass`, never `attestation: pass`, so the distinction reaches the audit trail.
4. **Attestation freshness is bounded by certificate lifetime.** A credential reflects the workload's state at admission, not at the moment a record is signed. Contrast's one-year certificate lifetime bounds this; a deployment wanting tighter bounds should rotate pods.
5. **This is not production-ready.** It is implemented, reviewed and tested. It has not been operated.
6. **No endorsement is implied.** Edgeless Systems has not reviewed this work. All Contrast behaviour described is cited to public source and documentation.

WHY THE BOUNDARIES ARE THE ARGUMENT

The verifier reports simulated rather than pass on a Contrast development platform, and absent rather than pass when no Coordinator root was pinned. A system that will not round its own evidence up in those cases is one whose pass is worth something. The same discipline is applied to this document.

9 • Proposed next steps

9.1 The one technical step that changes the most

Verify the hardware quote from the certificate's own extensions.

Contrast's mesh certificate already carries the complete quote — the quote body, its ECDSA signature, the attestation key, and the **PCK certificate chain** at 1.3.9901.2.2.46. Reassembling that into a wire-format quote and verifying it against Intel DCAP collateral would mean:

- The **attestation** domain reaches **pass** on a Contrast receipt, rather than honestly reporting **mock**.
- The Coordinator leaves the trusted set **for the hardware claim**. It still controls admission, but a reader no longer takes its word that the silicon was real.
- A Cool × Contrast receipt becomes verifiable **to silicon, offline, without trusting the Coordinator** — which, as far as we can tell, nothing else currently offers for AI governance evidence.

This is a focused piece of work on Cool's side. It needs no change to Contrast, though confirmation from Edgeless that the extension set is intended to be stable would reduce the risk of building on it.

9.2 A short sequence that de-risks the rest

Step	Who	What it settles
Technical review of the binding and trust model	Edgeless engineering	Whether the seam we chose is the one they would have chosen, and whether the extension set is stable to build on
One run on real TDX or SEV-SNP	Either side with cluster access	Removes the largest caveat in both documents in a single afternoon
Independent quote verification against DCAP	Northwind Cipher	Takes the Coordinator out of the trusted set for the hardware claim
Joint reference architecture, published	Both	A citable artefact for enterprise conversations on both sides
Confidential-GPU attestation joined to the evidence	Both	Extends the story to GPU inference, where the AI governance questions are sharpest

9.3 What we are asking for now

A technical conversation, not a commitment. Specifically: thirty minutes with someone who knows the Coordinator, to check the binding design against how Contrast is intended to be used, and to tell us whether the certificate extension set is something we should be depending on.

Everything needed to have that conversation is reproducible in about ten minutes:

```
git clone https://github.com/Northwind-Cipher/cool-sdk.git
cd cool-sdk && npm install
npm run demo:contrast    # seven acts, ~90 seconds, no cluster required
npm test                 # 152 tests, 33 of them this integration
```

And the two documents

This one, and the companion technical documentation, which carries the architecture, the exact binding, the trust model, the threat table, the full test matrix and a line-by-line source citation for every Contrast behaviour relied on.